

취약점 진단 방법





학습내용

- 취약점 진단 방법의 개요
- 취약점 진단 프로세스



학습목표

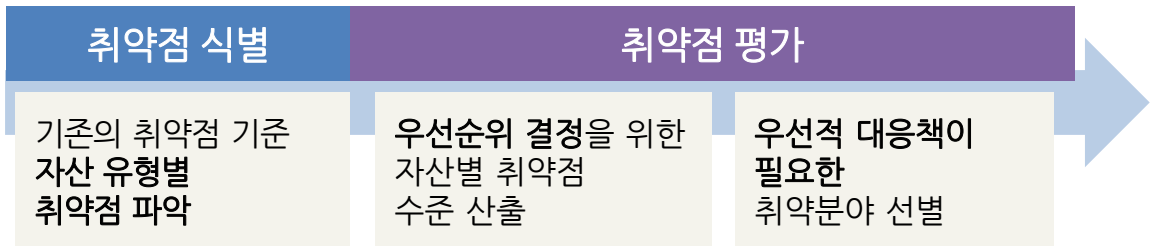
- 취약점 진단 방법을 설명할 수 있다.
- 취약점 진단 프로세스를 적용할 수 있다.

🔑 취약점 진단 방법의 개요

1. 취약점 진단

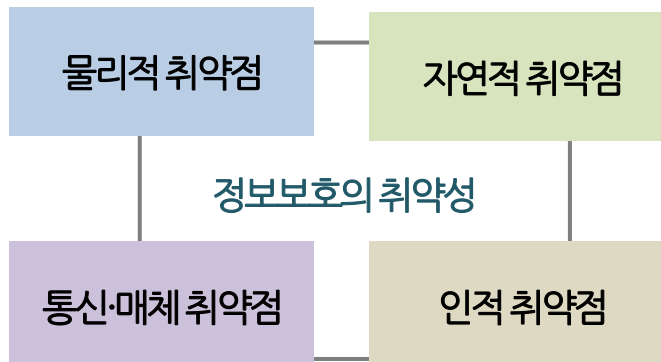
1) 취약점 취약점

- 취약점 : 외부 위협과 만나 위험을 발생시키는 **자산 자체의 약점**
- 취약점 진단 방법 : 자산분석 → 자산의 속성 및 중요도 평가 → 취약점
- 취약점 진단 과정



※ 자산의 중요도가 높은 자산이 취약점으로 인해
동작 불능 시 조직에 더 큰 피해를 줄 수 있음

2) 취약점의 종류



“반드시 4가지 모두를 고려할 것!”

취약점 진단 방법의 개요

(1) 인적 취약점

- 서버와 네트워크 장비들이 있는 통제구역/사무실과 같은 **제한구역에 대한 취약점**
- 시스템 파괴, 화재, 전력이상 및 부품 탈취 혹은 모바일 기기 반·출입으로 인한 **중요 정보 유출이나 악성코드 감염** 등의 문제 발생

(2) 자연적 취약점

- 화재, 홍수, 지진, 번개 등으로 인한 IT 시스템 중단/파손 등의 피해 발생 가능성

(3) 통신·매체 취약점

- 허가받지 않은 사용자가 네트워크/서버에 접근하는 **접근통제의 문제** 발생
- 시스템의 운영 미비로 인한 데이터 손실 등 **운영보안에 관련된 문제** 발생

(4) 인적 취약점

- 보안에 대한 교육 미비 혹은 인적 관리 미비로 **중요 정보 누설** 등의 **문제** 발생

🔑 취약점 진단 방법의 개요

2. 취약점의 특징



- 모든 자산은 **잠재적**으로 취약점을 가지고 있음, 보안적으로 완벽한 것은 존재하지 않음
- 취약점 그 자체만으로는 어떠한 위협도 초래하지 않고 **위협에 의해 이용될 때만 위협이 발생함**
- 대응책과 **관리가 늘어날수록** 취약점은 감소함
- 대응책도 **잠재적**으로 취약점을 가지고 있음

취약점 진단 프로세스

1. 취약점 식별 방법

1) 물리적 취약점(점검 사항)

(1) 물리적 보호구역 지정

- 통제·제한·접견구역을 지정하고 보호대책 수립, 이행
- 보호설비의 구축, 운영 절차의 수립, 운영
- 계약서의 작성, 주기적 검토(외부 집적정보통신시설에 위탁 운영 시)
- 작업절차의 수립, 기록, 주기적 검토
- 출입의 통제, 주기적 검토(책임추적성 확보)
- 모바일 기기의 반·출입 통제, 절차 수립, 기록, 관리

(2) 시스템 보호

- 통신통신케이블이나 전력케이블 보호
- 시스템 특성에 따라 분리배치, 위치 확인 체계 수립

(3) 사무실 보안

- 개인 → 중요 문서 관리, 화면보호기 설정, 비밀번호 노출금지
- 공용 → 공용 기기를 통한 정보유출 대책 마련

취약점 진단 프로세스

● 물리적·환경적 취약점 식별 방법의 예

물리적 취약점

- 출입 통제 시스템 혹은 직원의 부재
- 출입구나 창문 등의 잠금 장치 미흡
- 부적절한 장비의 위치 지정

환경적 취약점

- 항온·항습 장치의 부재, 미흡
- 화재 진압 장치의 부재, 미흡
- 침수에 취약한 위치 선정

2) 자연적 취약점(점검 사항)

(1) IT 재해 복구 체계 구축

- 자연재앙, 해킹 등의 요인으로 **IT 시스템 중단 또는 파손 등 피해 발생**에 대비
- 비상 시 복구조직, 비상연락체계, 복구절차 등 **IT재해복구체계** 구축

(2) 영향분석에 따른 복구 대책 수립

- 조직의 핵심 서비스 연속성을 위협할 수 있는 **IT 재해 유형 식별, 피해규모 및 영향 분석**
- IT 서비스 및 시스템 복구목표시간, 복구시점 정의
- 적절한 **복구전략 및 대책 수립 · 이행**

(3) 시험 및 유지 관리

- IT 서비스 복구전략 및 대책에 따라 효과적인 복구가 가능한지 **시험 실시** - 시험계획 : 시나리오, 일정, 방법, 절차 등
- 시험결과, IT 환경변화, 법규 등 **변화를 반영한 복구전략 및 대책 보완**

3) 통신·매체 취약점(점검 사항)

(1) 시스템 부문

- 인증 메커니즘, 접근통제, 감사 증적, 복잡한 사용자 인터페이스 변경통제의 부재/미흡
- 소프트웨어 패치 관리의 미흡
- 서버 취약한 포트 현황, 백도어 현황, 취약한 서비스 점검(FTP, Sendmail, 웹서버)
- 파일 접근권한, 소유자 관계, 신뢰 관계, 관리자 권한, 사용계정 및 패스워드, 보안패치, 시스템환경 등

(2) 네트워크 부문

- 네트워크 전체 구성 현황, 점검 도구 및 체크리스트에 의한 진단 설정
- 불필요한 서비스, SNMP취약점, 로그 관리, 라우팅 프로토콜, Telnet/console/aux 제어
- 보안 Access List 설정 현황 및 환경설정파일 점검

(3) 정보보호 시스템 부문

- 정보보호 시스템의 부재/미흡 및 정보보호 시스템 업그레이드 등의 관리 미흡
- 암호 키 관리의 부재/미흡
- F/W 및 IDS에 대한 Rule-set 점검, 로그점검, 구성 상 오류 보안 정책 변경 절차

(4) 응용프로그램 부문

- DNS, 웹서버 등에 대한 취약점 점검
- 데이터베이스 등에 대한 취약점 점검(접근권한, 데이터관련 정책 점검, 자동점검 등)

(5) PC 부문

- PC 보안 현황 분석(파일 공유, 패드워드 설정 등)

(6) 시스템 개발

- 분리되지 않은 개발, 테스트, 운영 설비
- 보안 요구사항의 불충분한 적용
- 변경관리, 형상관리의 미흡

4) 인적 취약점(점검 사항)

(1) 정보보호 교육 시행 및 평가

- 정보보호 관리체계 범위 내 **정보보호 교육 시행**
- 정보보호 정책 및 절차의 중대한 변경, 조직 내·외부 보안사고 발생, 관련 법규 변경 등 **사유가 발생할 경우 추가 교육 시행**
- 교육 시행에 대한 **기록 및 평가**

(2) 외부자 보안 이행 관리

- 외부자의 계약서 및 협정서에 명시된 **보안요구사항의 이행여부 관리 감독, 주기적인 점검/감사 수행**
- 외부자와의 계약 만료, 업무 종료, 담당자 변경 시 **정보자산의 반납, 정보시스템 접근계정 삭제, 중요정보 파기, 비밀유지 협약서 등의 내용 확인**

(3) 정보보호 책임 및 직무 관리

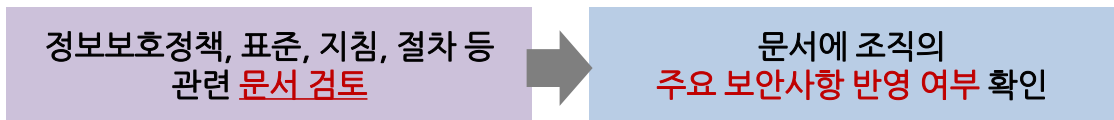
- 중요정보를 대량으로 취급하는 임직원의 경우 **주요 직무자 지정 및 지정 최소화** 등 보호대책 수립
- **직무분리** : 고의적인 행위로 인해 발생할 수 있는 잠재적인 피해를 줄이기 위하여 직무 분리 기준 수립 및 적용
→ 직무분리가 어려운 경우 별도의 보안통제 마련
- **퇴직 및 직무변경 관리** : 관련 부서에서 이행해야 할 자산반납, 접근권한 회수·조정, 결과 확인 등의 절차 수립

🔑 취약점 진단 프로세스

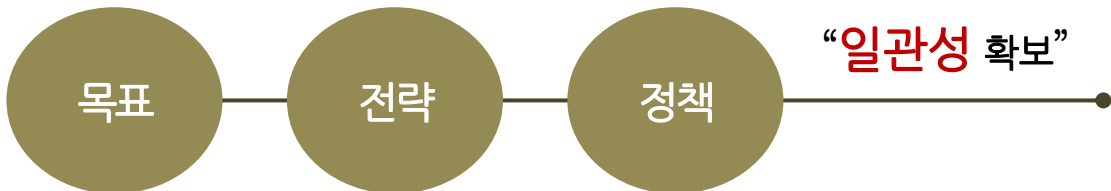
2. 취약점 진단 방법

1) 관리적 취약점

(1) 관리적 취약점 진단 방법



(2) 효율적인 IT 보안을 위한 조직수준, 사업단위 구성



2) 물리적 취약점



🔑 취약점 진단 프로세스

3) 기술적 취약점

(1) 시스템 진단 방법

자동 점검

- **자동화 점검도구** 이용
→ 많은 취약점을 빠르게 찾아 보호대책 제시
- 자동점검항목에 속하지 않는 취약점에 대해서는 점검 불가능
- 점검항목 : 자동점검도구의 종류와 점검방식에 따라서 조금씩 차이가 있음

수동 점검

- **전문가**가 직접 점검
→ 중요한 취약점은 **체크리스트** 이용

단점보완

(2) 시스템 진단 방법의 예

Windows 계열

- 보안성 진단 : **시스템 배치파일**
- 체크리스트 : 윈도우용 체크리스트를 바탕으로 서버에 직접 접속하여 보안성 진단

Linux/Unix 계열

- 보안성 진단 : **셸스크립트**
- 체크리스트 : 리눅스용 체크리스트를 바탕으로 서버에 직접 접속하여 보안성 진단

(3) 네트워크 장비에 대한 진단 방법

① 직접테스트

- 취약점에 대한 **Exploit을 이용하여 직접 테스트**
- 대상 시스템의 정상적인 동작범위 안에서 테스트 수행
- 예) 버퍼 오버플로우 공격 시도, **Default 또는 단순한 패스워드 확인**

② 버전 및 설치 패치 확인

- Exploit 방법이 공개되지 않은 취약점 점검 시 시스템 다운 취약점 점검
- **서비스 버전이나 레지스트리를 통한 패치 정보 점검**
- 예) 서비스 팩이나 Hotfix 확인, SMTP/OpenSSH 서비스의 취약한 버전 확인

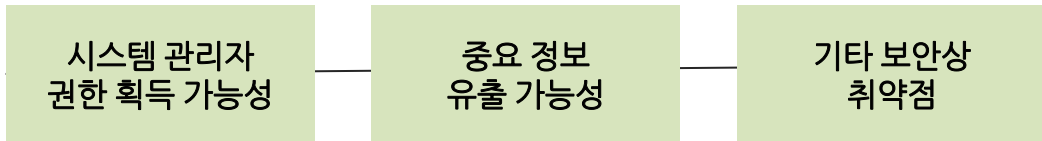
③ 서비스 가동 여부

- 점검 시 서비스나 시스템 다운 취약점 점검
- **불필요한 서비스 점검 및 취약점이 알려진 CGI 존재 여부 점검**
- 예) 취약한 CGI나 Echo, Time 등

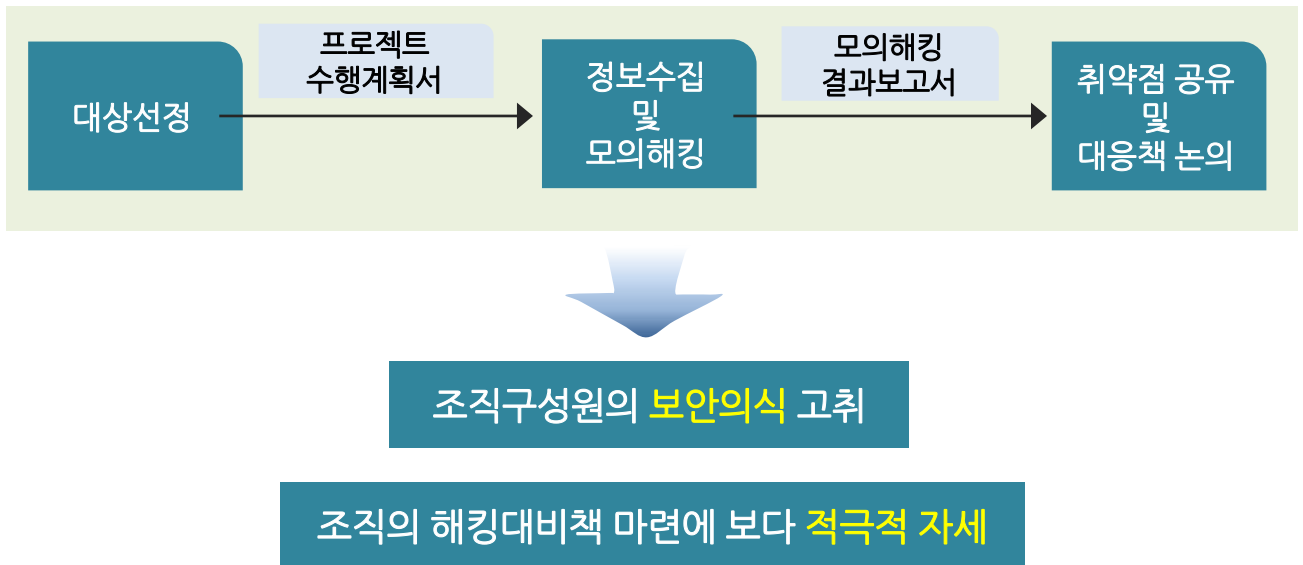
🔑 취약점 진단 프로세스

(4) 웹 애플리케이션에 대한 진단 방법

① 모의 진단/해킹 시 중요 점검 항목



② 모의 해킹 절차



취약점 진단 프로세스

3. 취약점 평가

조직의 성격에 따라
취약성 평가를 세분화
(3단계, 4단계, 5단계)

1) 4단계 구분의 평가 기준 설정의 예

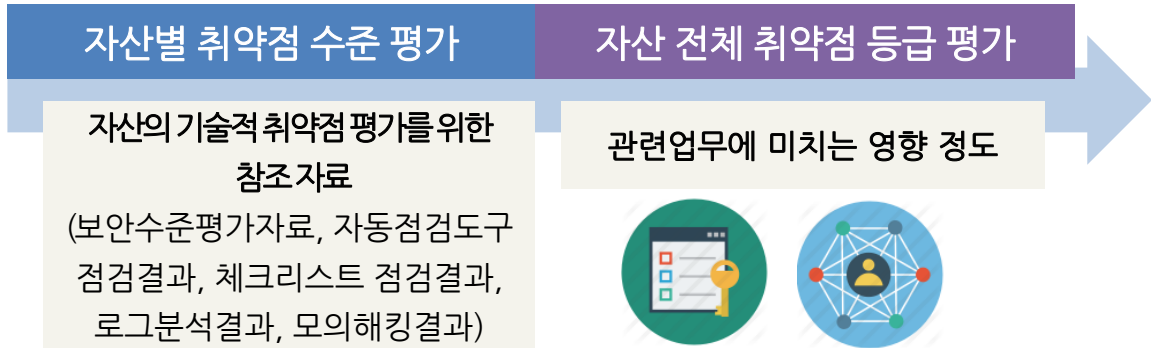
매우취약 (VH)	자산의 복구가 불가능하거나 피해규모가 아주 큰 경우
비교적취약 (H)	최고 경영자나 상급관리자의 정밀한 검색 및 승인을 필요로 하며 위험을 발생시킬 수 있는 경우 자산의 복구는 가능하나 그 피해규모가 비교적 큰 경우
보통(M)	취약점이 상급관리자의 검토 및 승인을 필요로 하는 정도의 위험을 발생시킬 수 있는 경우
거의취약 하지않음(L)	취약점이 자산에 별다른 영향을 끼치지 않거나 취약점이 자산에 약간의 영향은 끼치지만 그 영향이 미미해서 해당 자산이 담당자의 조치만으로 문제해결이 가능한 경우

2) 취약점 수준 평가

- 취약점 진단 결과 즉, 설문, 면담 등에서 나온 **관리적 취약점**, 체크리스트에서 나온 **물리적 취약점** 그리고 자동 점검 또는 체크리스트에서 나온 **기술적 취약점** 등에 대한 영향 정도를 평가하는 작업

🔑 취약점 진단 프로세스

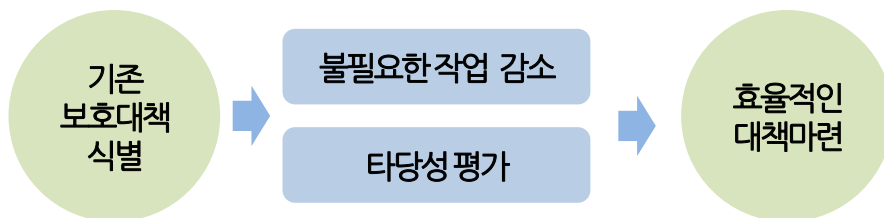
3) 취약점 수준 평가 방법



4) 기존 보호 대책 분석의 필요성

- 관리적·물리적·기술적 취약점에 대해 기존 보호 대책이 어떻게 적용되고 있는지 분석하는 것은 발견된 취약점에 대한 **보호 대책을 작성하기 위해** 반드시 필요한 작업

5) 기존 보호 대책 분석 및 보완



“기존 보호 대책이 가진 **문제점의 보완 또는 해결** 가능”

6) 기존 보호 대책 분석 시 확인 사항

- 정보보호 관리 문서 분석 : 기존 정보보호정책서 및 관련 보안지침, 보안규정과 정보보호 현황 분석서를 통한 **현행 시스템에 대한 보호 대책 현황 분석**
- 위협 시나리오에 대한 현행 보호대책 확인 : 현재 어떤 보호대책이 적용되고 있는지 확인 및 관련지침, 절차 식별
- 정보자산에 대한 현행 보호대책 및 이행여부 확인 :
보안수준평가자료를 참조로 하여 서버 및 네트워크자산, 응용시스템 등에 대한 현행 보호대책 확인 및 이행 여부 확인

핵심요약

1. 취약점 진단 방법의 개요

1) 취약점 진단

- 자산분석을 통하여 도출된 자산의 속성과 중요도를 바탕으로 자산이 근본적으로 가지고 있는 약점인 취약점을 발굴하고 취약점이 전체적인 위험에 미칠 수 있는 영향을 분석하는 과정

2) 취약점의 종류

- 물리적 취약점, 자연적 취약점, 통신·매체적 취약점, 인적 취약점

2) 취약점 특징

- 모든 자산이 잠재적으로 가지고 있으며, 취약점은 그 차체만으로는 어떠한 위협도 초래하지 않고 위협에 의해 이용될 때 위험 발생

핵심요약

2. 취약점 진단 프로세스

1) 취약점 식별 방법

- 물리적 취약점 : 물리적 보호구역 지정, 시스템보안, 사무실 보안
- 자연적 취약점 : IT 재해복구 체계 구축, 영향분석에 따른 복구대책 수립
- 통신-매체적 취약점 : 시스템 부문, 네트워크 부문, 정보보호 시스템 부문, 응용프로그램 부문, PC부문, 시스템개발
- 인적 취약점 : 정보보호 교육, 외부자 보안 이행, 정보보호 책임 및 직무 관리

2) 취약점 진단 방법

- 관리적 취약점 : 조직의 주요 보안사항의 적절한 반영여부 확인
- 물리적 취약점 : 체크리스트를 이용하여 직접 물리적 환경 진단
- 기술적 취약점 : 시스템 진단(자동 점검, 수동 점검), 네트워크 장비, 웹 애플리케이션

3) 취약점 평가

- 취약점 평가 기준 설정 : 조직의 성격에 따라서 취약점 평가를 세분화하여 구분
- 취약점 수준 평가 : 자산별로 취약점 수준 평가 후, 자산의 전체 취약점에 대해 취약점 등급 평가
- 기존보호대책 분석 : 관리적, 물리적, 기술적 취약점에 대해 기존 보호대책이 어떻게 적용되고 있는지 분석하는 것